软件安全属性及度量元设计

一、安全属性的定义与分解

国防科技大学可信属性分层模型，将软件实体可信属性分为可用性、可靠性、安全性、实时性、可维护性和可生存性。其中，安全性进一步分为数据保密性、代码安全性和控制保本文沿用这一分解方式。

1. 安全属性的定义

NIST 收录的安全定义强调，信息和信息系统应受到保护，避免未经授权的访问、使用、泄露、修改和破坏。结合本次作业中的模型，可以将软件的安全性理解为：**软件在规定的运行条件下，保护数据、程控制权限，使其不被未授权主体获取、利用或篡改，并按既定安全规则运行的能力。** 这里的定义是结合资料作出的概括。资料来源：NIST Security

例如，在一个学生成绩管理系统中，安全性不仅要求学生不能看到其他人的成绩，还要求程序不存在容易被利用的漏洞，普通账号也不能绕过权限检查修改成绩。

2. 三个子属性的涵义

子属性	涵义	以成绩管理系统为例
数据保密性	软件在数据存储、处理和传输过程中，防止信息被未经授权的人员、程序或设备获取、推断或泄露的能力。关注的是数据内容是否得到保护。	学生只能查看允许查看的成绩；成绩文件不能被匿名下载；日志不应直接记录账号口令等敏感信息。
代码安全性	软件通过安全设计、编码、检查和修改，减少可被利用的代码缺陷，并防止程序被非法修改或植入恶意代码的能力。关注的是程序本身是否存在安全隐患。	查询语句采用参数化方式，避免 SQL 注入；输入经过校验；发布程序与经过测试的版本一致。
控制保密性	本文将其理解为对软件控制权限及相关敏感控制信息的保护能力，使身份凭据、管理接口和特权操作只对被授权主体开放，防止冒用身份、越权操作和非法接管。	学生账号不能调用教师修改成绩的接口；管理员凭据不能泄露；退出登录后，原会话不能继续执行管理操作。

数据保密性的解释参考了 NIST 对保密性的定义；代码安全性的解释参考了安全软件开发框架中减少漏洞及其影响的思路。保密性资料、安全软件开发框架

课件图中列出了“控制保密性”，但没有展开解释。因此，本文参考访问控制中“按既定规则允许或拒绝访问”的含义，将它具体落实到身份、权限和敏感控制信息的保护上。这是本次度量设计采用的解释，不作为模型原文的逐字定义。访问控制资料

三者会有联系，但检查重点不同：数据保密性检查“信息是否泄露”，代码安全性检查“程序是否有可利用的缺陷”，控制保密性检查“谁能控制系统、能执行哪些操作”。

二、基于全生命周期的度量元设计

按照课件的格式，从需求分析、软件设计、编码实现和软件测试四个阶段设计度量元。每个子属性设置 6 个定量度量元，共 18 个。

度量值统一采用：

$$r = 1 - \frac{u}{v}$$

其中，v 为该项应检查的对象总数，u 为其中未满足要求的对象数，r 越接近 1，说明该项完成得越好。每个对象在同一度量元内只计一次。对象清单应先经过评审，不能在计算时删掉未完成的项目。

没有检查记录的对象不算合格；测试失败、尚未执行或结果无法确认的用例都计入 u。若某项确实不适用、$v = 0$，则注明原因并记为“不适用”，不直接赋值为 1。

1. 数据保密性

开发阶段	名称	类型	度量元
需求分析	数据保密需求完整性	定量	$r = 1 - u/v$。u 为未明确保密要求的敏感数据项数；v 为根据业务和数据清单确定的全部敏感数据项数。要求应说明谁能访问、在哪些环节需要保护。
软件设计	数据保密设计覆盖性	定量	$r = 1 - u/v$。u 为没有对应保护设计的保密需求数；v 为全部数据保密需求数。检查存储、传输、显示、导出及日志中的保护设计。
编码实现	数据保护实现符合性	定量	$r = 1 - u/v$。u 为未实现或实现不符合设计的数据保护项数；v 为设计规定的全部数据保护项数，如传输加密、敏感字段脱敏、备份文件保护等。
编码实现	敏感信息输出合规性	定量	$r = 1 - u/v$。u 为存在违规敏感信息输出或未完成检查的输出点数；v 为应检查的全部敏感信息输出点数，包括日志、报错信息、页面和导出文件。
软件测试	保密测试覆盖性	定量	$r = 1 - u/v$。u 为没有相应用例的保密需求数；v 为全部数据保密需求数。测试应覆盖存储、传输及使用过程中的泄露风险。
软件测试	保密测试通过率	定量	$r = 1 - u/v$。u 为未通过、未执行或结果无法确认的保密测试用例数；v 为评审确定的全部适用保密测试用例数。

取数依据主要是敏感数据清单、需求规格说明书、设计说明书、代码检查记录和保密测试报告。比如，测试计划确定了 40 个用例，36 个通过、2 个失败、2 个未执行，则该项为 $1 - 4/40 = 0.90$，不能只按已经执行的用例计算。

2. 代码安全性

开发阶段	名称	类型	度量元
需求分析	代码安全要求完整性	定量	$r = 1 - u/v$。u 为没有形成明确要求的适用代码安全检查项数；v 为经风险分析确认的全部适用检查项数，包括输入校验、异常处理、依赖组件和发布包完整性等。
软件设计	安全设计覆盖性	定量	$r = 1 - u/v$。u 为未给出设计措施的代码安全要求数；v 为全部代码安全要求数。检查措施是否落实到模块、接口或发布流程。
编码实现	安全编码检查符合性	定量	$r = 1 - u/v$。u 为不符合规范或未完成检查的检查项数；v 为本版本全部适用的“模块—规则”检查项数。例如，对一个查询模块检查参数化查询，计为一项。
编码实现	已知代码安全问题修复率	定量	$r = 1 - u/v$。u 为尚未修复或修复后未通过复查的问题数；v 为本轮评估截至统计日累计确认的代码安全问题数。重复报告合并，误报经确认后排除。
软件测试	代码安全测试覆盖性	定量	$r = 1 - u/v$。u 为未被测试用例覆盖的适用代码安全要求数；v 为全部适用代码安全要求数，包括注入防护、异常输入处理和篡改程序拒绝加载等。
软件测试	代码安全测试通过率	定量	$r = 1 - u/v$。u 为未通过、未执行或结果无法确认的代码安全测试用例数；v 为评审确定的全部适用代码安全测试用例数。

取数依据主要是安全编码规范、设计评审记录、代码审查记录、静态分析报告、问题跟踪记录和测试报告。修复率只能反映已经发现的问题处理得怎样，不能据此认定程序不存在其他漏洞。严重问题也需要单独列出，不能被大量普通问题的修复结果掩盖。

3. 控制保密性

开发阶段	名称	类型	度量元
需求分析	权限与控制信息需求完整性	定量	$r=1-u/v$。u 为未明确授权规则或保密要求的受保护对象数；v 为全部受保护对象数，包括特权操作、管理接口和身份凭据等。
软件设计	控制保护设计覆盖性	定量	$r=1-u/v$。u 为没有对应设计措施的控制保密需求数；v 为全部控制保密需求数。检查身份鉴别、权限判断、凭据保护和会话失效设计。
编码实现	权限校验实现符合性	定量	$r=1-u/v$。u 为缺少权限校验、校验错误或未完成检查的受控入口数；v 为全部应进行权限校验的入口数。入口包括页面对应的服务端接口、管理接口和后台任务入口。
编码实现	控制凭据保护符合性	定量	$r=1-u/v$。u 为保护措施不符合要求或未完成检查的凭据处理点数；v 为全部凭据处理点数。检查口令、令牌、管理密钥在生成、存储、传输和失效环节的处理。
软件测试	授权规则测试覆盖性	定量	$r=1-u/v$。u 为没有同时设计允许访问和拒绝访问测试的授权规则数；v 为权限矩阵中的全部适用授权规则数。
软件测试	控制保密测试通过率	定量	$r=1-u/v$。u 为未通过、未执行或结果无法确认的控制保密测试用例数；v 为评审确定的全部适用控制保密测试用例数，包含身份冒用、越权、凭据泄露、会话失效及正常授权操作测试。

取数依据主要是角色权限矩阵、身份鉴别设计、接口清单、凭据处理检查记录和权限测试报告。以修改成绩为例，既要验证学生账号不能修改成绩，也要验证被授权的教师能够正常修改，不能把“所有请求都拒绝”当作安全功能正确。

三、基于出厂报告的度量元设计

这一部分按课件的“可信属性—子属性—度量元”格式填写，每个子属性设置 A、B、C、D 四个等级，A 级最高。以下条件是本次作业设计的评审标准，并非国防科技大学模型已经规定的统一等级阈值。

评审时，以出厂报告及其附件为依据，附件应注明软件版本、检查范围和测试结果。同一子属性先检查是否满足 A 级，再依次检查 B、C 级，取能够完整满足条件的最高等级；达不到 C 级则为 D 级。这里的“关键要求”应在需求评审时确定，例如敏感数据不能被未授权读取、普通用户不能取得管理员权限。

可信属性	子属性	度量元
安全性	数据保密性	**A：** 敏感数据清单完整，各项保密需求均有对应设计和测试证据；存储、传输、显示、日志和导出等适用环节均完成检查；全部适用保密测试通过，已确认的泄露问题全部完成修复和复测，材料可追溯到出厂版本。
安全性	数据保密性	**B：** 敏感数据清单及必要报告齐全，全部明确的保密要求均有验证结果，测试通过，发现的问题均已修复并复测；但异常场景的扩展验证或需求到测试的追溯材料尚不完整，不影响对关键要求的确认。
安全性	数据保密性	**C：** 所有关键数据保密要求已有验证证据且满足要求；仍有非关键检查项未完成或一般问题未关闭，报告已逐项说明影响、临时保护措施、责任人和整改期限，并有评审认可记录。
安全性	数据保密性	**D：** 不满足 C 级条件。例如存在未解决的关键数据泄露问题，或者敏感数据清单、关键保护措施的验证材料缺失，无法确认关键保密要求得到满足。
安全性	代码安全性	**A：** 安全编码检查、代码审查、静态分析及适用动态安全测试均已完成，检查范围覆盖本次交付代码和使用的第三方组件；已确认的问题全部修复并复测通过，发布包完整性验证通过，报告中的代码与出厂版本一致且可追溯。
安全性	代码安全性	**B：** 已完成规定的代码安全检查和测试，全部明确的代码安全要求得到验证，已确认问题均已修复并复测，发布包完整性验证通过；但深度检查、组件检查或过程追溯尚未达到 A 级的完整程度。
安全性	代码安全性	**C：** 关键模块和关键代码安全要求已经验证，未发现尚未处理的高风险或严重漏洞；仍有非关键范围未检查或一般问题未关闭，报告已给出影响分析、临时措施、责任人和整改期限，并有评审认可记录。
安全性	代码安全性	**D：** 不满足 C 级条件。例如存在未处理的高风险或严重漏洞，无法确认交付程序来源及完整性，或者缺少关键模块安全检查和测试证据。
安全性	控制保密性	**A：** 角色权限矩阵、管理接口及凭据清单完整，身份鉴别、授权判断、凭据保护和会话管理均有验证记录；正常授权、未授权访问、横向越权、纵向越权及适用异常场景测试全部通过，发现的问题全部修复并复测，证据可追溯到出厂版本。
安全性	控制保密性	**B：** 权限规则和必要报告齐全，所有明确的控制保密要求均验证通过，发现的问题全部修复并复测；但复杂角色组合、异常会话等扩展验证或全过程追溯材料不如 A 级完整。
安全性	控制保密性	**C：** 关键管理操作、管理凭据和关键授权边界均已有验证证据且满足要求；非关键场景仍有检查遗漏或一般问题，报告已说明影响、临时限制措施、责任人和整改期限，并有评审认可记录。

可信属性	子属性	度量元
安全性	控制保密性	**D：** 不满足 C 级条件。例如普通账号仍能执行关键管理操作、管理凭据存在未解决的泄露问题，或者缺少关键权限边界的验证材料。

两种方法使用的证据有所不同。全生命周期度量更适合找出哪个阶段、哪个环节存在不足；出厂报告度量则把需求、设计、检查和测试结果集中起来，供评审人员判断。即使某些比例指标较高，只要仍存在关键数据泄露或管理员权限可被绕过的问题，也不能据此认为软件已经满足安全要求。

参考资料

1. NIST：Security，信息安全术语资料。
2. NIST：Confidentiality，保密性术语资料。
3. NIST：Access Control，访问控制术语资料。
4. Souppaya M., Scarfone K., Dodson D.：Secure Software Development Framework（SSDF）Version 1.1，NIST SP 800-218，2022。